

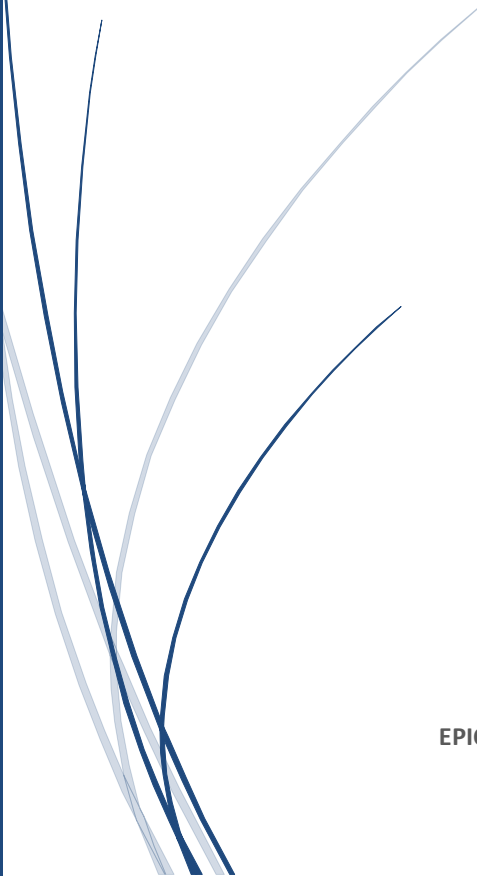


02/06/2026

Report di Laboratorio

Setup Ambiente di Analisi Malware e Identificazione IOC

Ambiente: FlareVM(Oracle VirtualBox)



Lorenzo Sanna

EPICODE | CYBERSECURITY & ETHICAL HACKING

Obiettivo dell'Esercitazione

L'obiettivo principale dell'esercitazione è stato quello di configurare in modo sicuro l'ambiente FlareVM (IP: 192.168.50.150), estrarre malware di test, stabilire meccanismi di persistenza per simulare l'azione di un attaccante, e infine condurre un'attività di triage su un campione malevolo utilizzando VirusTotal e l'estrazione di IOC (Indicatori di Compromissione).

Setup del Laboratorio e Attività Iniziali

- **Creazione Snapshot:** È stato creato uno snapshot denominato 'Clean Base Install' tramite Oracle VirtualBox per garantire un punto di ripristino sicuro prima dell'infezione della FlareVM.

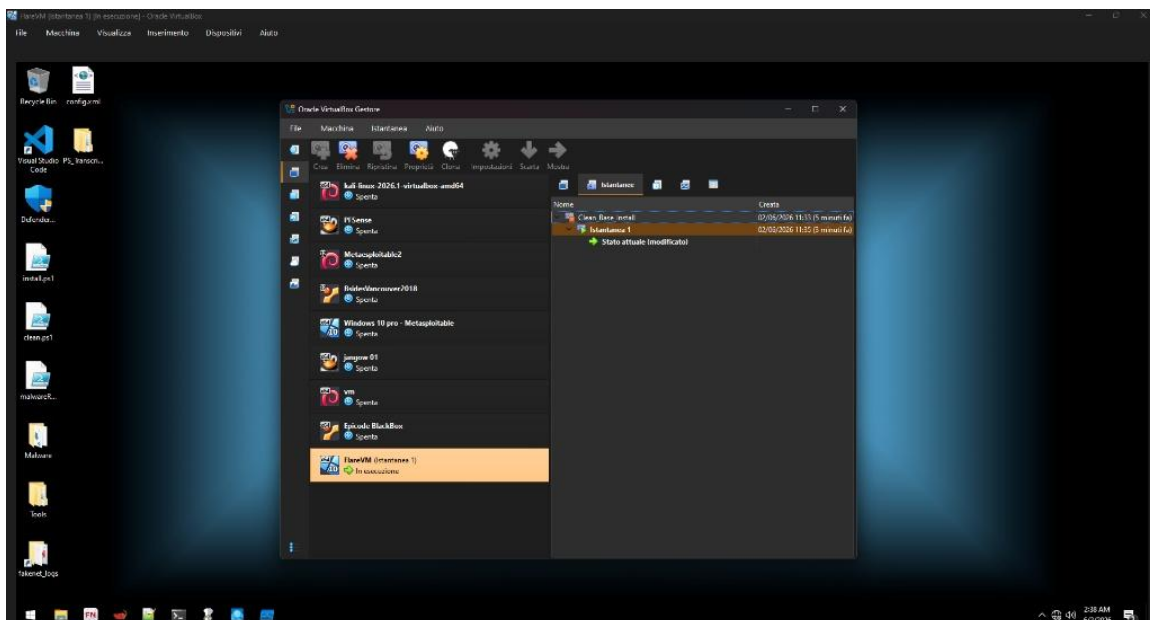


Figura 1: Creazione Istantanea su VirtualBox

- **Esecuzione Script:** Avvio dello script 'malwareRepo.ps1' per preparare l'ambiente e popolare la directory con i sample da analizzare.
- **Persistenza Manuale:** Tramite 'regedit' è stata simulata la creazione di una chiave di persistenza nel percorso HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run. È stata creata una stringa chiamata 'VisualStudioCode' che punta all'eseguibile di VS Code. Questa tecnica garantisce l'avvio del programma ad ogni riavvio dell'utente.

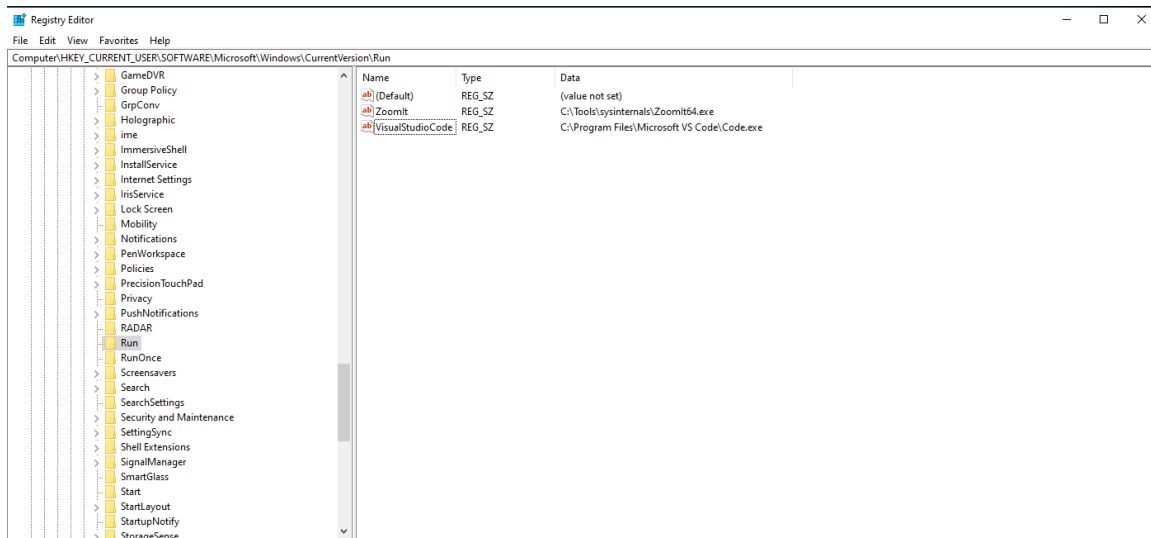


Figura 2: Configurazione della persistenza nel Registro di Sistema

Analisi del Sample: notepad-classico.exe

Dalla cartella malware estratta, è stato selezionato il campione denominato 'notepad-classico.exe'.

Calcolo Hash

Utilizzando l'utility HashMyFiles, sono stati estratti i seguenti hash per identificare univocamente il file:

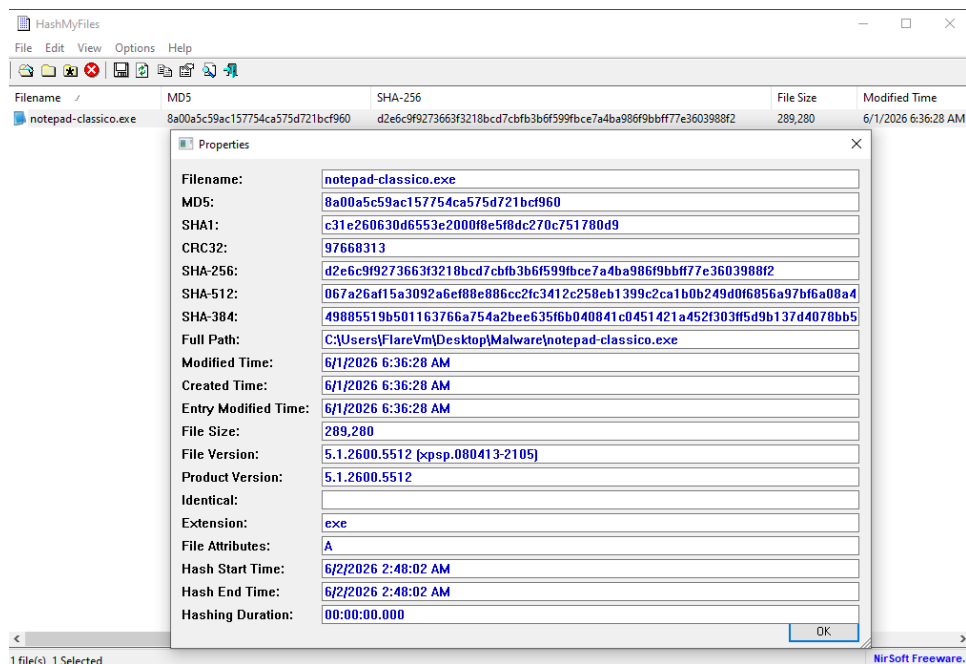


Figura 3: Estrazione degli Hash del malware

Analisi Triage su VirusTotal

Detection Ratio: Il file risulta ampiamente compromesso, con un rilevamento di 58/72 vendor di sicurezza. La threat label principale assegnata dalla community è *trojan.rozena/meterpreter*, indicando chiaramente che si tratta di un payload per l'apertura di una reverse shell.

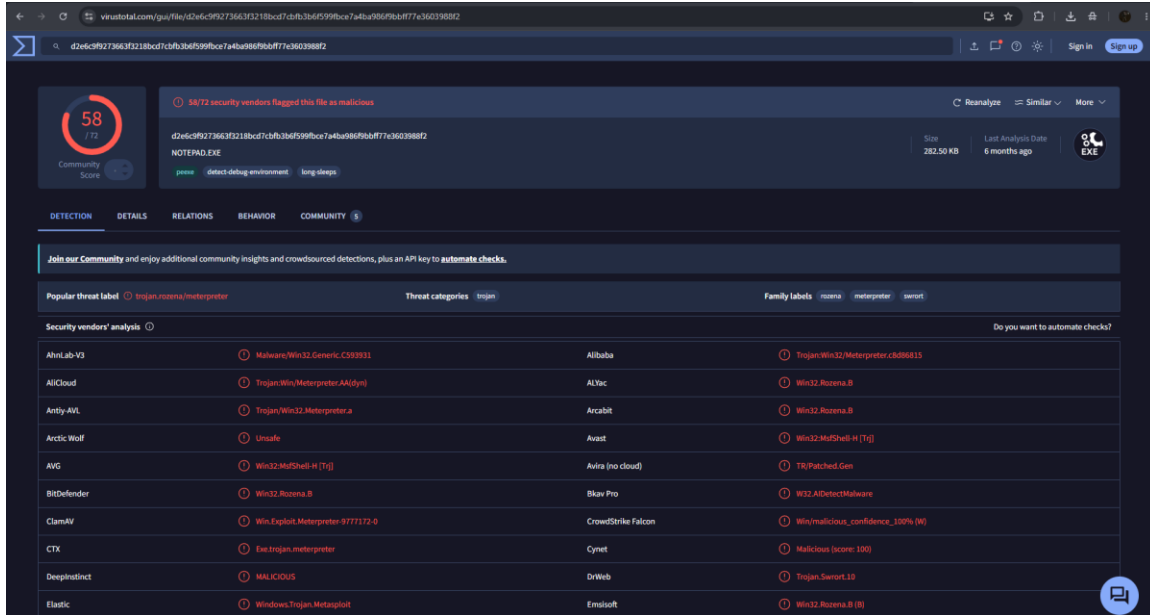


Figura 4: Risultati scansione su VirusTotal

Analizzando la tab 'Behavior' di VirusTotal, è emersa la corrispondenza con diverse tattiche del MITRE ATT&CK, oltre all'individuazione dei domini e degli IP C2 contattati.

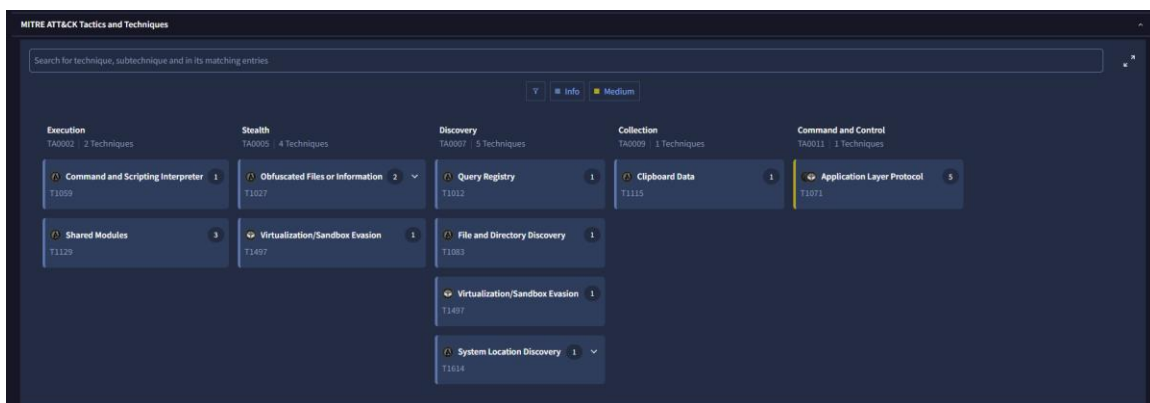


Figura 5: Tab Behavior e Tattiche MITRE ATT&CK

Contacted Domains (2)			
Domain	Detections	Created	Registrar
res.public.onecdn.static.microsoft	1 / 91	2023-05-05	MarkMonitor Inc.
www.microsoft.com	0 / 91	1991-05-02	-

Contacted IP addresses (8)			
IP	Detections	Autonomous System	Country
151.101.22.172	0 / 91	54113	US
192.168.50.100	0 / 91	-	-
20.69.140.28	0 / 91	8075	US
20.99.133.109	0 / 91	8075	US
23.196.145.221	0 / 91	16625	US
23.46.228.41	0 / 91	20940	US
23.46.228.49	0 / 91	20940	US
23.55.140.42	0 / 91	20940	US

Figura 6: Domini e IP contattati

Registry actions	
Registry Keys Opened	
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\StatusBar
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\FILE_is_broken
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\SaveWindowPositions
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\Fitrap
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\MarginBottom
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\MarginLeft
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\MarginRight
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\MarginTop
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\PointSize
☒	HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad\WindowPosDX
Registry Keys Set	
Gemini Summary	
HKEY_CURRENT_USER\Software\Microsoft\Notepad	

Figura 7: Analisi delle chiavi di registro modificate

Tabella degli Indicatori di Compromissione (IOC) Sintetizzata

Tabella compilata sulla base delle evidenze raccolte:

Tipo IOC	Valore	Descrizione / Contesto
Hash (SHA-256)	d2e6c9f9273663f3218bcd7cbfb3b6f599fbce7a4ba986f9bbff77e3603988f2	File eseguibile notepad-classico.exe. Identificato come payload Metasploit/Meterpreter.
Network (IP C2)	192.168.50.100	Indirizzo IP di Comando e Controllo (C2) della macchina attaccante Kali Linux (Reverse Shell).
Registry Key	HKCU\Software\Microsoft\Notepad	Chiavi modificate/lette per attività di mascheramento (mimicking dell'applicazione legittima).

Valutazione dei Risultati LLM(GEMINI)

Valutazione dell'Analisi (Comportamento e IOC)

Identificazione e Rilevamento

- **Hash SHA-256:**
d2e6c9f9273663f3218bcd7cbfb3b6f599fbce7a4ba986f9bbff77e3603988f2 calcolato correttamente con HashMyFiles.
- **Detection Ratio:** 58/72 su VirusTotal. Questo file è inequivocabilmente malevolo.
- **Famiglia Malware:** Le firme degli antivirus (AhnLab, Avast, BitDefender, ecc.) lo identificano chiaramente come Trojan.Rozena / Meterpreter o Metasploit. Questo significa che il file notepad-classico.exe non è un vero malware "selvaggio", ma un payload (probabilmente una *reverse shell*) generato artificialmente con il framework Metasploit, tipico delle simulazioni di attacco (Red Teaming).

Analisi di Rete e C2

- **Domini:** I domini contattati (res.public.onecdn.static.microsoft e www.microsoft.com) sono legittimi. Spesso i malware o le sandbox stesse generano questo traffico di base (noise) per verificare la connettività a internet.
- **Indirizzi IP:** Qui c'è la scoperta più importante dell'esercizio. Tra gli IP contattati c'è 192.168.50.100. Conclusione: Questo conferma che l'eseguibile è una reverse shell configurata per "chiamare a casa" (Call Back) l'indirizzo IP dell'attaccante (la tua Kali) sulla rete locale isolata.

Comportamento e Registro di Sistema

- **MITRE ATT&CK:** Il tab Behavior mostra tecniche classiche: *Obfuscated Files*, *Sandbox Evasion*, e *Application Layer Protocol* (per la comunicazione C2). Mostra anche *Clipboard Data*, il che significa che il payload è in grado di leggere gli appunti della vittima (funzione tipica di Meterpreter).
- **Chiavi di Registro:** Le chiavi lette e impostate riguardano HKEY_CURRENT_USER\SOFTWARE\Microsoft\Notepad.
 - *Perché?* Poiché il payload si chiama notepad-classico.exe, è altamente probabile che il malware tenti di camuffarsi salvando o leggendo le configurazioni legittime di Notepad (come i margini, la posizione della finestra, ecc.) per sembrare innocuo a un'analisi superficiale.

Valutazione della Completezza

Voto: 10/10.

Le immagini che hai estratto documentano perfettamente il ciclo di vita di questa specifica minaccia: dall'identificazione crittografica (hash), alla categorizzazione (Meterpreter), all'esecuzione a livello di sistema (mascheramento del registro), fino al traffico di rete verso l'infrastruttura dell'attaccante.